

BUG: Potential use-after-free bug in function

Py_FindObjects #14713

Closed

#15013

Snape3058 opened on Sep 10, 2021

Describe your issue.

This is a bug report generated by a static analyzer, the path provided by the static analyzer is as follows. This static analysis report has been manually reviewed to verify its validity.

1. A new reference is returned from function `PyList_New`, assigned to variable `result`.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 878 in 8ef5830

```
878     result = PyList_New(max_label);
```

2. Assume the following creations return `NULL`, a *no memory* exception will be thrown. e.g.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 890 in 8ef5830

```
890     PyErr_NoMemory();
```

3. Goto label `exit`.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 891 in 8ef5830

```
891     goto exit;
```

4. The first decrement on variable `result`.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 924 in 8ef5830

```
924     Py_XDECREF(result);
```

5. Take the true branch, as there is an exception thrown.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 930 in 8ef5830

```
930     if (PyErr_Occurred()) {
```

6. The second decrement on variable `result`, which is a use-after-free bug.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 931 in [8ef5830](#)

```
931     Py_XDECREF(result);
```

Reproducing Code Example

Static analysis results, no POC.



Error message

Static analysis results, no error messages.



SciPy/NumPy/Python version information

commit [8ef5830](#)



Snape3058 added **defect** on [Sep 10, 2021](#)

tupui on Sep 10, 2021 · edited by tupui

Edits ▾

Member



Hi [@Snape3058](#), thanks for the details. But [Py_XDECREF](#), as opposed to `Py_DECREF`, is taking care of NULL as per the doc so there should be no problem no? Or you are saying that we don't need this last call?

Snape3058 on Sep 10, 2021

Author



Function `PyList_New` returns a new reference and is then assigned to variable `result`. Let's assume it is not NULL. As a new reference it is, we assume (in our analyzer) the refcnt is 1. After the first `Py_XDECREF`, the refcnt becomes 0, and the PyObject that `result` points to will be destroyed. Then the second `Py_XDECREF` will decrease the refcnt to -1, which is a potential use-after-free bug.

It is not the matter of `x` for NULL pointers, but the `DECREF`. This report is a use-after-free bug report, not a null pointer dereference report.

I made a test with the following code snippet, which is similar to the path in the report. The refcnt change of the PyObject is commented in the code.

```
void f() {
    PyObject *result = PyList_New(1); // <-- new reference returned (line 878)
    assert(result);
    printf("%ld\n", result->ob_refcnt); // 1

    PyErr_NoMemory(); // <-- error happens, an exception is thrown (line 890)
    Py_XDECREF(result); // <-- destruction here (line 924)
    printf("%ld\n", result->ob_refcnt); // 0

    if (PyErr_Occurred()) {
        Py_XDECREF(result); // <-- use after free here (line 931)
```



```
printf("%ld\n", result->ob_refcnt); //-1
}
```

1

  **rgommers** added `scipy.ndimage` on Oct 7, 2021

  **AnirudhDagar** mentioned this on Nov 10, 2021

 MAINT: Fix use-after-free bug in Py_FindObjects #15013

  **tupui** closed this as completed in [#15013](#) on Nov 11, 2021

  **rgommers** added this to the 1.8.0 milestone on Jul 10, 2023

 rgommers on Jul 11, 2023

Member ...

This issue just got assigned a CVE: <https://nvd.nist.gov/vuln/detail/CVE-2023-29824>. This is very similar to [#16235 \(comment\)](#) (Cc [@nonsense-j](#)), and seems invalid too. This use-after-free occurs when creation of a Python list of length "max number of labels for found objects" fails. This list is small compared to the image itself. So to even trigger the use-after-free, an attacker would have to be able to deterministically exhaust memory at the point where this API is called. It's quite similar to the use-after-free example under *Public disclosure preferred* in <https://www.python.org/dev/security/>. From that example:

While these are clearly important bugs to fix, and may, in some hypothetical situations, have a security impact, the only proof of concept the PSRT can imagine for any of them is to be able to execute arbitrary Python code. If you can already execute Python code, there are far worse things you can do than provoke a use-after-free or an interpreter crash.

So, it's a regular bug, but not a security issue.

 nonsense-j on Jul 12, 2023

...

@rgommers Thanks for your clear reassessment and explanation about this issue. I misunderstand the specific difference between CVE and bug, which caused some extra work for your team. Both of the two cves will be updated as reject. Besides, no more cves are requested except the two you mentioned. I will strictly follow responsible disclosure practices next time. Sorry again and so much appreciation.

 rgommers on Jul 12, 2023

Member ...

Thank you for confirming [@nonsense-j](#)!

  **SH2282000** mentioned this on Jul 18, 2023

🔒 Scipy dependency present the CVE-2023-25399 treeverse/dvclive#629

 JonnyLeiZhang on Jul 20, 2023

Hi [@rgommers](#),

When can the [CVE-2023-25399](#) be rejected? We got a alert on this in our project.

BR/Lei

 nonsense-j on Jul 20, 2023

I sent the update (reject) form on July 12th and the submission has been confirmed to be received by mitre. I can't be sure how long it will take, but I will submit the request again if it is not rejected later.

3

 JonnyLeiZhang on Jul 20, 2023

Oh one more question, will [CVE-2023-29824](#) be rejected too?

 nonsense-j on Jul 20, 2023

Yes, I have submitted reject forms for both of them.

3

 JonnyLeiZhang on Jul 31, 2023

hi [@nonsense-j](#) , any update?

 nonsense-j on Jul 31, 2023

Not yet. I just submitted two more requests for rejection and hope they can be resolved soon.



 **dhrubo-os** mentioned this [on Aug 22, 2023](#)

✔ [CVE-2023-29824 \(Critical\) detected in scipy-1.7.3-cp37-cp37m-manylinux_2_12_x86_64.manylinux2010_x86_64.whl opensearch-project/opensearch-py-ml#230](#)



 **vin01** mentioned this [on May 3, 2024](#)

🔗 [\[GHSA-jrfm-2h82-xg28\] Use after free in SciPy github/advisory-database#4338](#)



 **mmoras** mentioned this [on Sep 27, 2025](#)

 [CVE Finder, please take a look and update with the following recommendations mmoras/my-amazing-application#1](#)

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

defect

scipy.ndimage

Type

No type

Projects

No projects

Milestone



1.8.0

Closed on Feb 6, 2022, 100% complete

Relationships

None yet

Development



Code with agent mode



MAINT: Fix use-after-free bug in Py_FindObjects

scipy/scipy

Participants

